



ISC 互联网安全大会



360 互联网安全中心

阿里巴巴IPv6安全实践

程荣 阿里巴巴集团高级安全专家

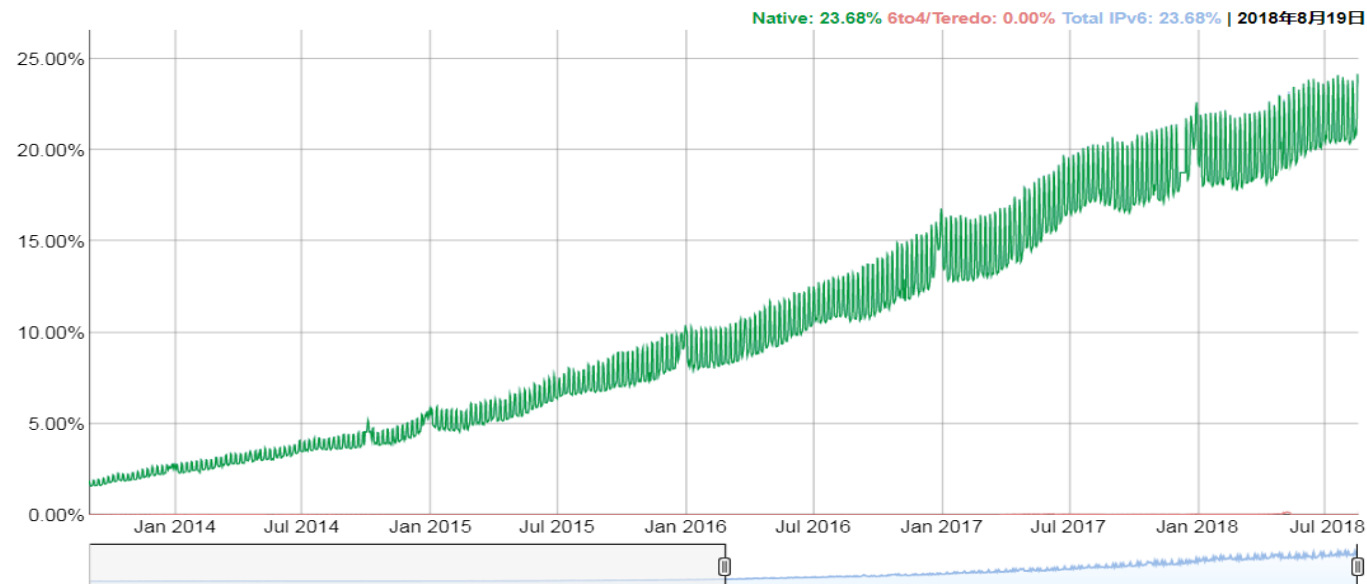
2018 ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
(原中国互联网安全大会)

目录

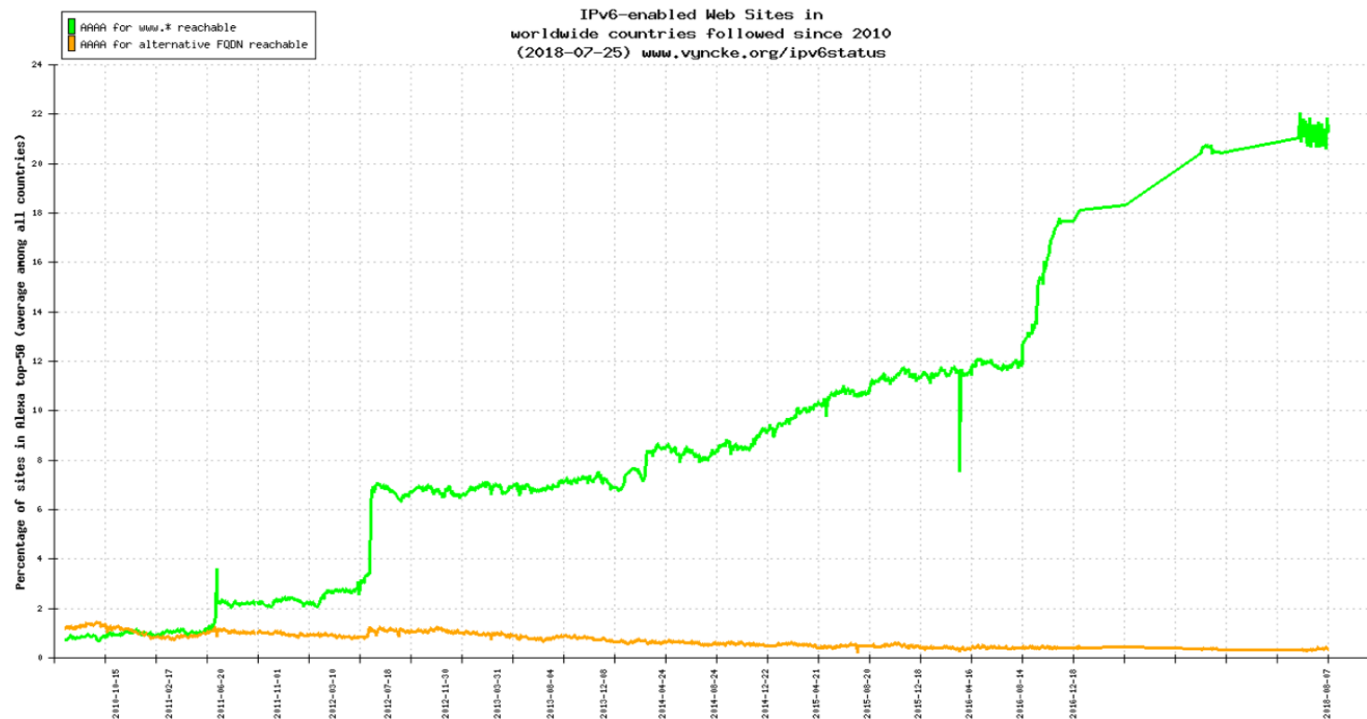
- 1、全球IPv6发展趋势及国内政策要求
- 2、阿里巴巴集团IPv6升级面临挑战及安全威胁
- 3、阿里巴巴集团IPv6改造及安全解决方案
- 4、未来IPv6安全的思考及展望

全球IPV6发展趋势及政策要求

全球IPv6发展趋势

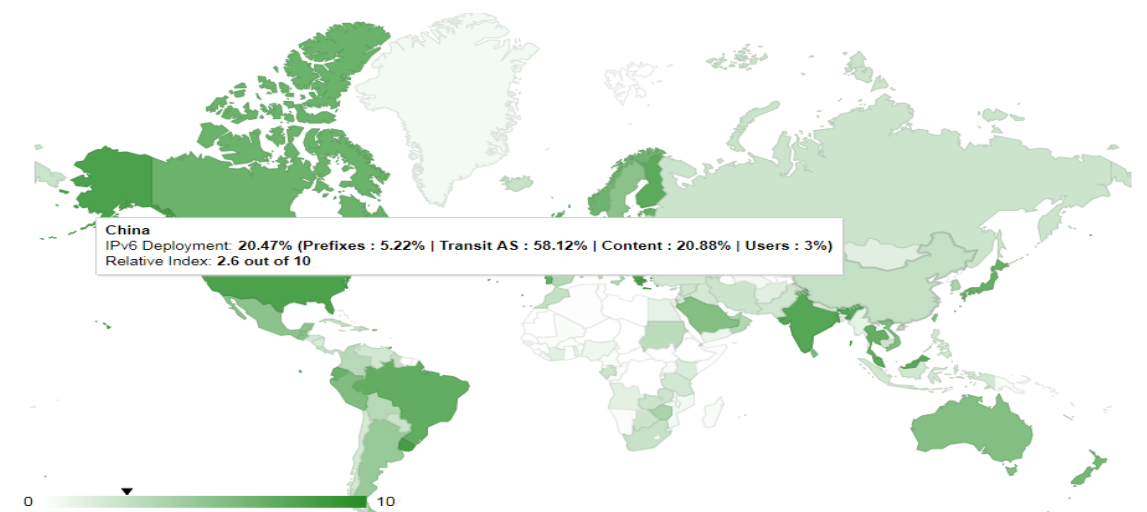
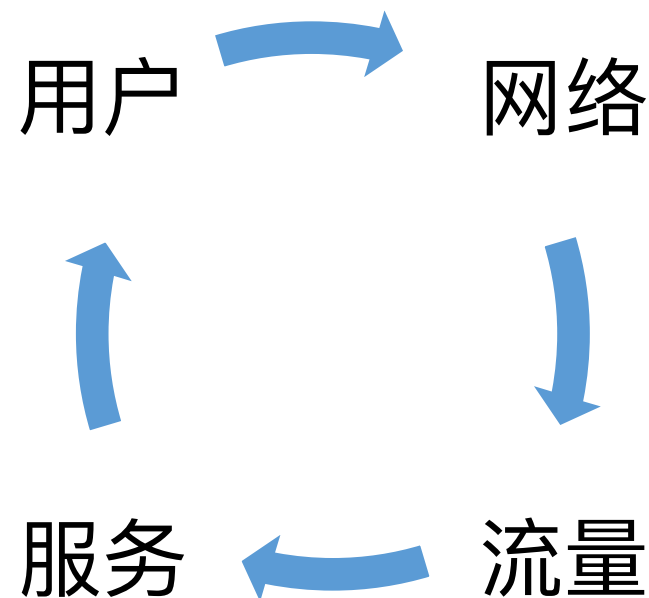


全球访问Google IPv6用户分比，目前已超过了20%，据预测2021年可超过50%

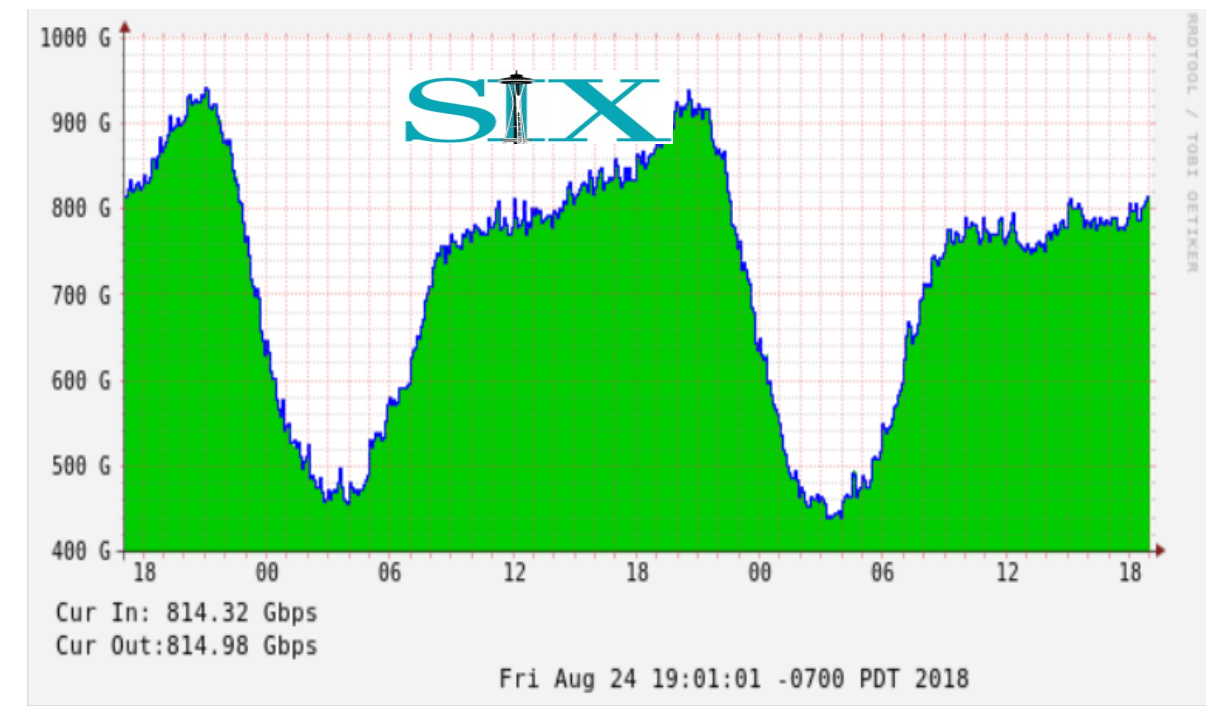


全球IPv6 Web服务增长趋势

ZERO TRUST SECURITY



基于国家IPv6网络部署和用户情况分布
美国: Deolymnt 51.75% Prefix 33.77% Users 38.9%
中国: Deolymnt 20.47% Prefix 5.22% Users 3%



IPv6流量变化趋势

国内IPv6发展及政策要求

Obsoleted by: [8200](#)
Updated by: [5095](#), [5722](#), [5871](#), [6437](#), [6564](#), [6935](#),
[6946](#), [7045](#), [7112](#)
Network Working Group
Request for Comments: 2460
Obsoletes: [1883](#)
Category: Standards Track

DRAFT STANDARD
Errata Exist
S. Deering
C. S. Rind
R. Hind
N. M.
December 1998

Internet Protocol, Version 6 (IPv6) Specification

Status of this Memo

This document specifies an Internet standards track protocol for the Internet community, and requests discussion and suggestions for improvements. Please refer to the current edition of the "Internet Official Protocol Standards" (STD 1) for the standardization state and status of this protocol. Distribution of this memo is unlimited.

Copyright Notice

Copyright (C) The Internet Society (1998). All Rights Reserved.

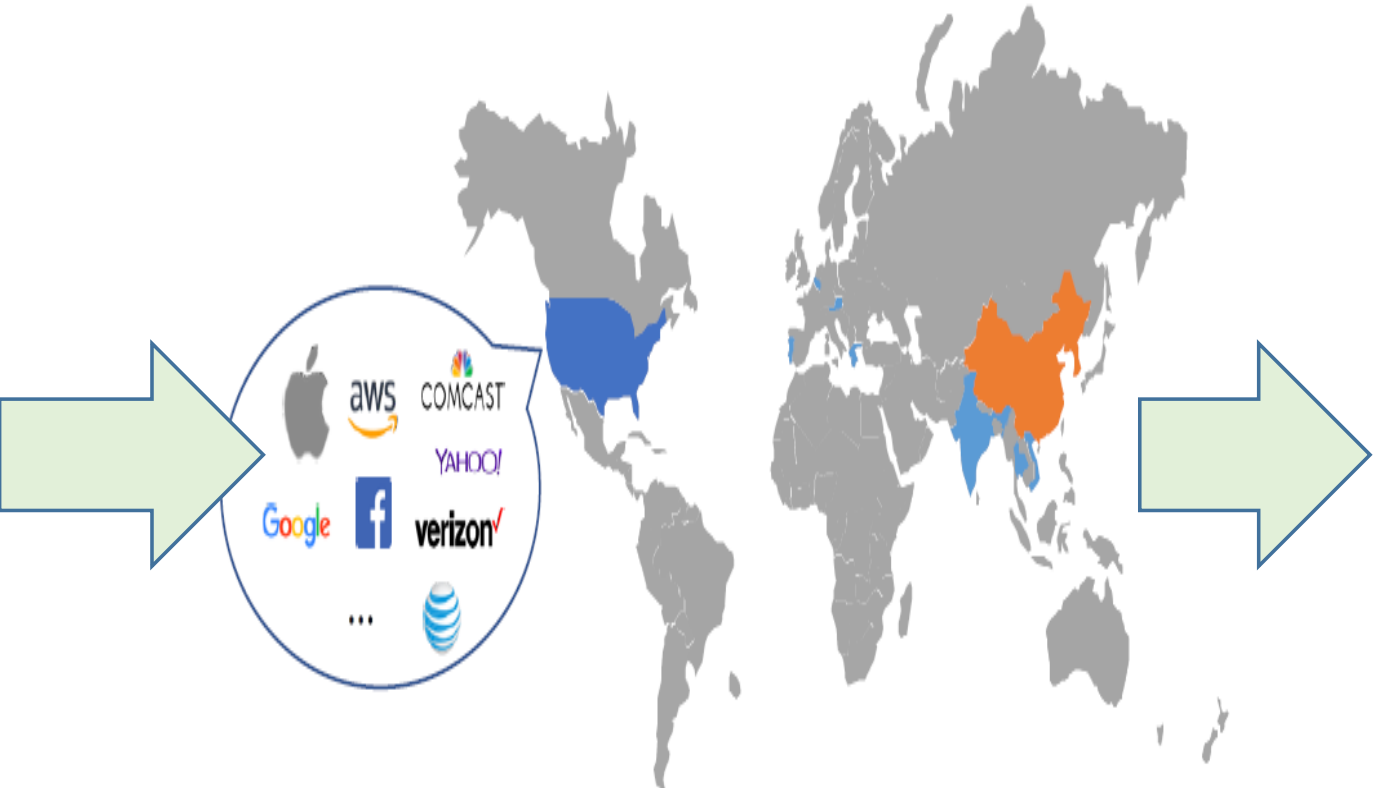
Abstract

This document specifies version 6 of the Internet Protocol (IPv6), also sometimes referred to as IP Next Generation or IPng.

Table of Contents

1. Introduction.....	2
2. Terminology.....	3
3. IPv6 Header Format.....	4
4. IPv6 Extension Headers.....	6
4.1 Extension Header Order.....	7
4.2 Options.....	9
4.3 Hop-by-Hop Options Header.....	11
4.4 Routing Header.....	12
4.5 Fragment Header.....	18
4.6 Destination Options Header.....	23
4.7 No Next Header.....	24
5. Packet Size Issues.....	24
6. Flow Labels.....	25
7. Traffic Classes.....	25
8. Upper-Layer Protocol Issues.....	27
8.1 Upper-Layer Checksums.....	27
8.2 Maximum Packet Lifetime.....	28
8.3 Maximum Upper-Layer Payload Size.....	28
8.4 Responding to Packets Carrying Routing Headers.....	29

首版IPv6协议规范（RFC2460）发布已20多年
产业进程一度停滞



少数商业公司推动了IPv6产业进程
Apple/Google/Facebook等以及北美部分无线
运营商推动，最终打破死循环，IPv6发展进
入快车道

个别经济体跟随，
发展迅速：



1998-2015:加入6Bone、CNGI工程
2016：信息化发展规划明确IPv6战略
2017.11：两办文件(IPv6规模部署计划)
2018.5：工信部通知（落实两办文件）
国内IPv6发展滞后，政策力度极大，
预计2020年关键应用使用IPv6会达到
50%

针对IPv6安全，计划中重点要求升级安全系统，强化IPv6地址管理，增强IPv6安全防护，加强IPv6环境工业互联网、物联网、车联网、云计算、大数据、人工智能等领域的网络安全技术、管理及机制研究，构筑新兴领域安全保障能力。

阿里巴巴IPV6升级面临挑战及安全威胁

阿里巴巴IPv6升级面临挑战



海量应用改造



运营商

客户端

IPv6地址/路由管理

互联网质量监控和流量调度
全球质量探测系统升级

L4-L7网关
SLB/WAF/FW/LVS等

安全
DDoS防护、流量清洗、网络隔离监控、业务风控等

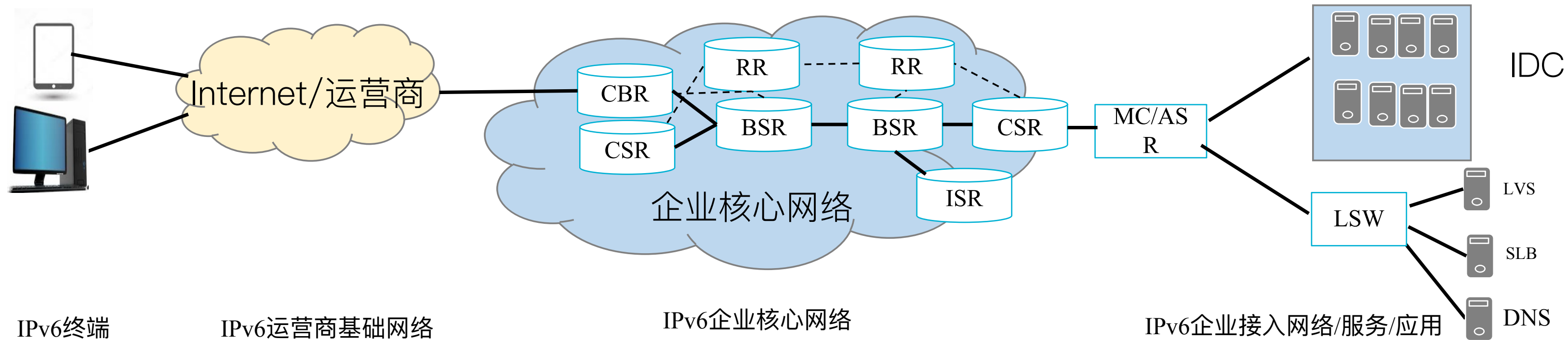
网络设备改造升级

IPv6协议栈
DNS/BGP/OSPF等协议栈

网络管理
海量自动化、监控工具开发

IPv6是网络，是IT infrastructure,更是整个生态能力的提升

阿里巴巴集团IPv6升级面临安全威胁



IPv6升级涉及的改造

IPv6协议栈 APP/应用		IPv6网络设备 IPv6路由管理 IPv6地址编址 IPv6地址分配		IPv6核心网络设备 IPv6路由管理分配 IPv6地址编址分配		IPv6接入		IPv6网站 IPv6 DNS/SLB/LVS 应用/业务 IPv6接入网络设备	
IPv6网关									

IPv6升级面临的安全威胁

IPv6协议栈漏洞利用 IPv6用户仿冒/僵尸蠕		IPv6 地址滥用 IPv6 不安全配置		IPv6 DDoS攻击 IPv6 路由/DNS劫持		IPv6设备认证绕过 IP过渡技术弱点利用		业务风控绕过 应用安全漏洞 (例如IP相关SSRF)	
-----------------------------	--	-------------------------	--	------------------------------	--	--------------------------	--	-------------------------------	--

阿里巴巴集团IPv6升级面临安全问题



ISC 互联网安全大会



360 互联网安全中心

- 1、**IPv6协议栈安全**：分片攻击、扩展头攻击、NDP攻击等
- 2、**IPv6安全检测及扫描**：地址空间变大使得实施IPv6扫描非常困难，对于攻击及防御双方都带来新的挑战。
- 3、**IPv6 DNS安全**：扫描困难的情况下公共节点可能会成为优先的攻击目标。
- 4、**IPv6 DDoS防护及黑洞**：DDoS防护涉及IPv6编址标准、运营商IPv6黑洞支持，需要多部门配合联动，挑战很大。
- 5、**IPv6 业务风控**：IPv6地址是很关键的一环，如何精确快速区分恶意用户及溯源？
- 6、**IPv6 安全产品改造**：协议栈升级及地址相关的策略及逻辑改造面大，成本高。
- 7、**IPv6 网络安全**：IPv6地址空间大，做好规划及地址分配策略，同时网络访问控制及隔离、扫描都要配套升级。
- 8、**IPv6过渡技术安全**：过渡技术安全控制措施并不完善，需要结合其他方案综合控制风险。

IPv6协议栈安全、DNS安全、安全检测与扫描

◆ 针对IPv6协议特点进行的攻击

◆ 分片攻击

◆ **NDP协议攻击**: ND Spoofer针对ARP的攻击如ARP欺骗、ARP泛洪等在IPv6协议中仍然存在,同时IPv6新增的NS、NA、RS、RA也成为新的攻击目标。Attack tools exist (from THC – The Hacker'sChoice) Parazit6/Fakerouter6...

◆ **扩展头攻击**: 当前协议对IPv6扩展头数量没有做出限制,同一种类型的扩展头也可以出现多次。攻击者可以通过构造包含异常数量扩展头的报文进行DoS攻击。

◆ **IPv6 DNS攻击**: IPv6的SLACC协议支持任一节点都可以上报DNS域名和IP地址,本意是通过该协议提高DNS的更新速率,但是这样带来了冒用域名的风险。

◆ IPv6 报文格式

◆ **128位地址空间**: 攻击者扫描更加困难,但IPv6地址如果易仿冒,安全监控和防御也困难。

Type 0 Routing Header Amplification Attack

- What if attacker sends a packet with a Routing Header containing
 - $A \rightarrow B \rightarrow A \rightarrow B \rightarrow A \rightarrow B \rightarrow A \rightarrow B \rightarrow A \dots$
- Packet will loop multiple times on the link R1-R2
- An amplification attack!

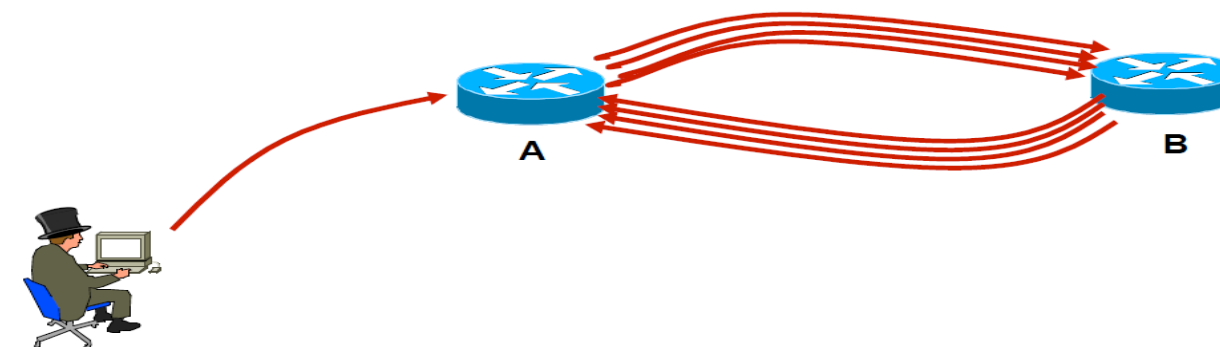


Diagram illustrating the IPv4 Header structure (32 bits total):

bit	0	8	16	24	31
Version	IHL		Service Type		Total Length
Identifier			Flags	Fragment Offset	
Time to Live		Protocol		Header Checksum	
32 bit Source Address					
32 bit Destination Address					
Options and Padding					

IPv4 Header
20 octets, 12 fields, including 3 flag bits
+ fixed max number of options

Diagram illustrating changes in IPv4 header fields:

Changed	Removed
---------	---------

Diagram illustrating the IPv6 Header structure (40 bits total):

bit	0	4	12	16	24	32
Version	Class		Flow Label			
Payload Length				Next Header		Hop Limit
128 bit Source Address						
128 bit Destination Address						

IPv6 Header
40 octets, 8 fields + Unlimited Extension Headers

Frame 1 (423 bytes on wire, 423 bytes captured)

Raw packet data

Internet Protocol Version 6

Hop-by-hop Option Header

Destination Option Header

Routing Header, Type 0

Hop-by-hop Option Header

Destination Option Header

Routing Header, Type 0

Destination Option Header

Routing Header, Type 0

Transmission Control Protocol, Src Port: 1024 (1024), Dst Port: bgp (179), Seq: 0, Ack: 0, Len: 51

Border Gateway Protocol

Perfectly Valid IPv6 Packet According to the Sniffer

Header Should Only Appear Once

Destination Header Which Should Occur at Most Twice

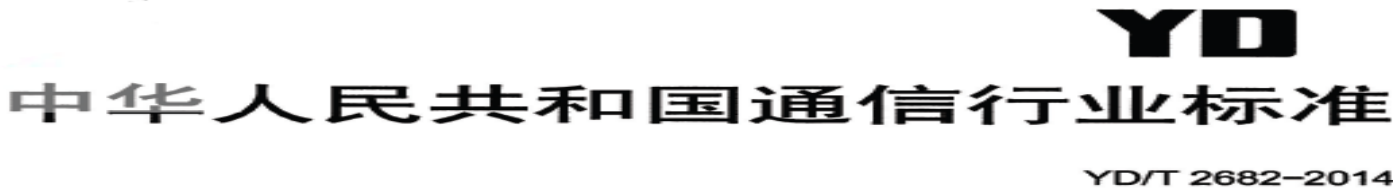
Destination Options Header Should Be the Last

◆ IPv6地址及分配

- ◆ 《IPv6接入地址编址编码技术要求》
- ◆ 各运营商、教育网及企业IPv6编址及分配规范

◆ IPv6地址与DDoS、业务风控及安全产品

- ◆ DDoS防护：用户IPV6地址空间增大对于攻防双方是把双刃剑，清晰统一的编址、精确溯源可以降低DDoS防御的成本与效率。
- ◆ 业务风控：防止薅羊毛、作弊、欺诈等
- ◆ 安全产品改造：需结合各自安全产品业务逻辑判断升级改造，特别是和IP地址相关的安全数据、情报、扫描探测等相关逻辑



2014-05-06 发布 2014-05-06 实施
中华人民共和国工业和信息化部 发布

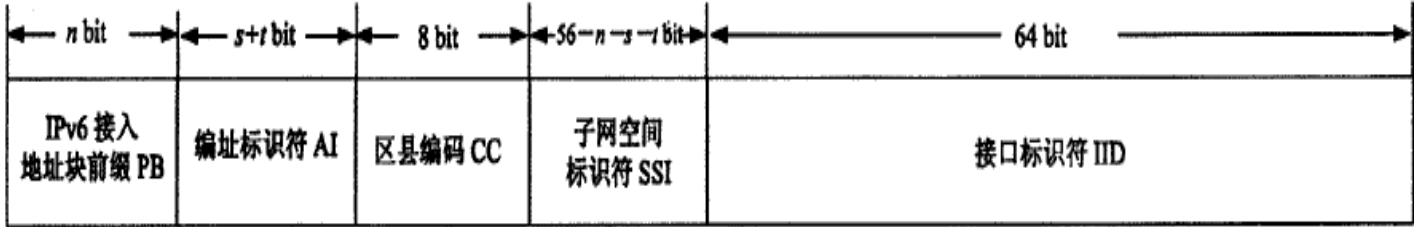


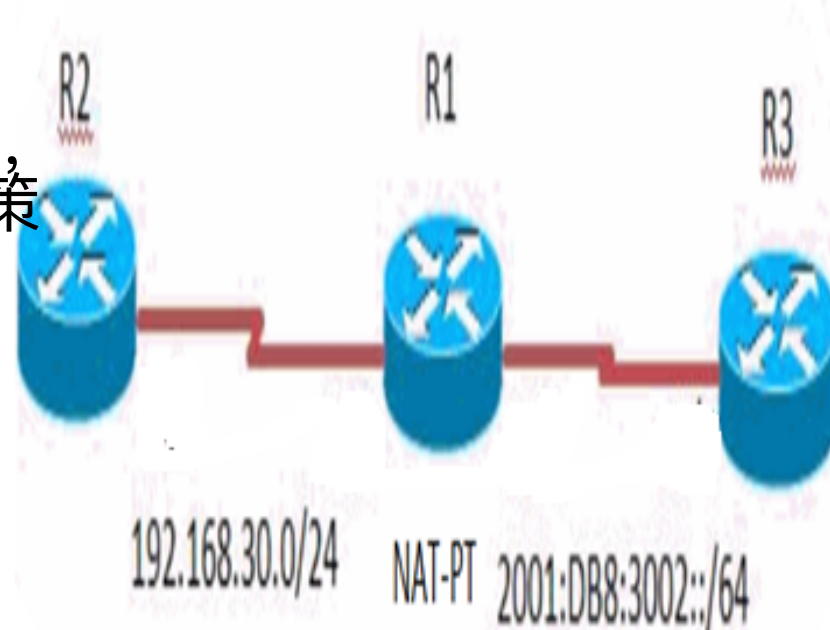
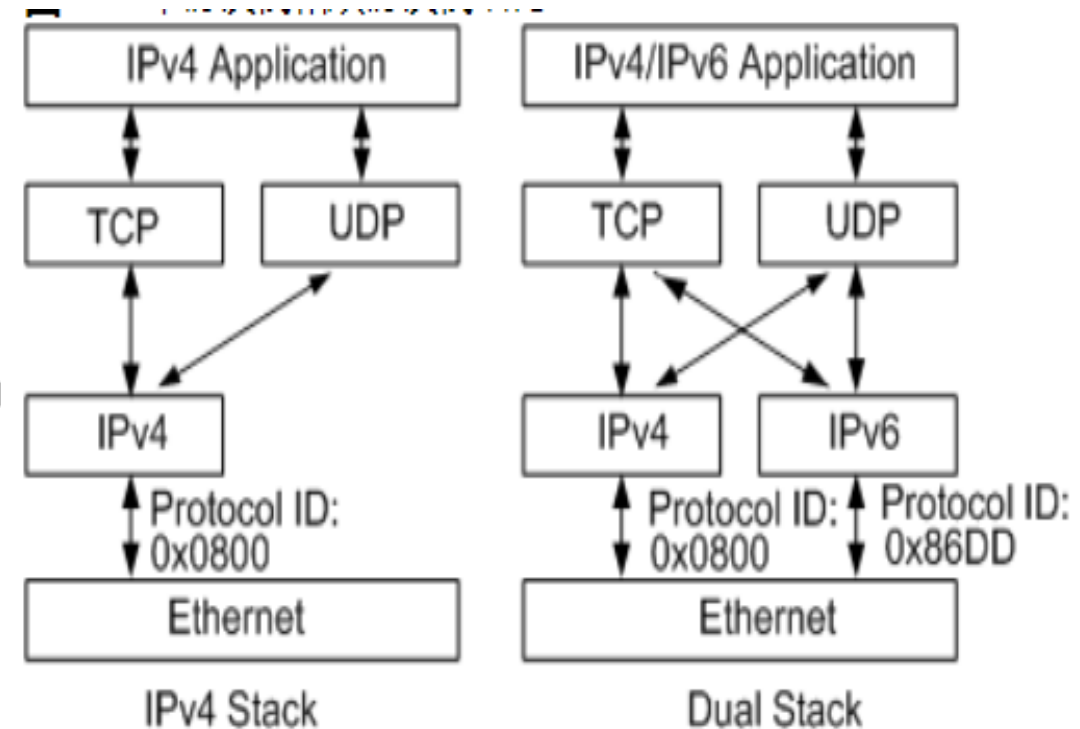
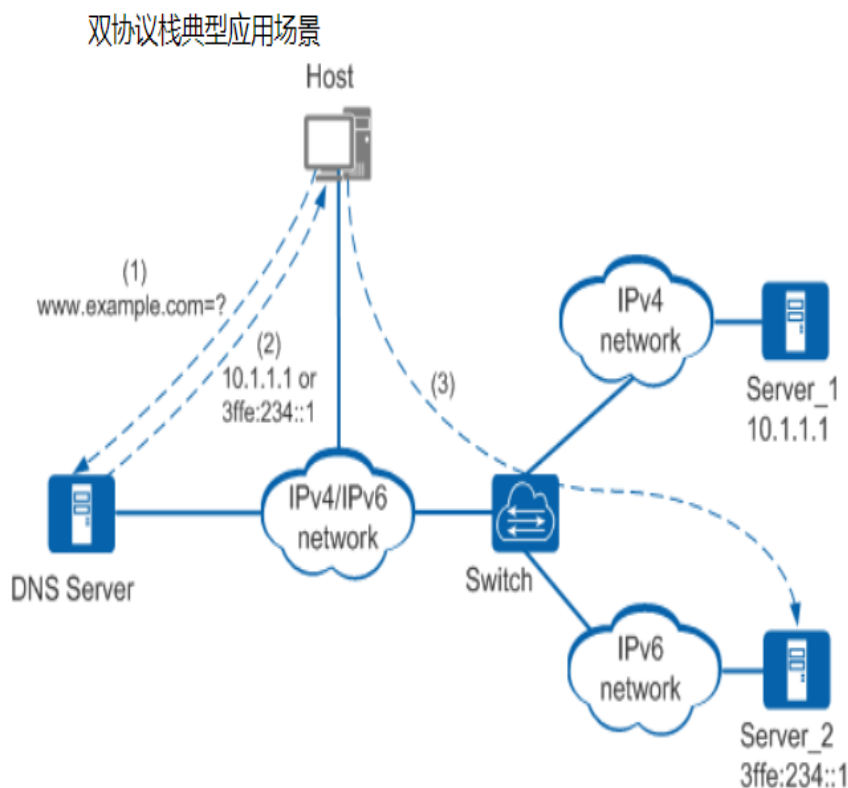
图3 用户设备接入地址格式

◆ IPv6网络安全

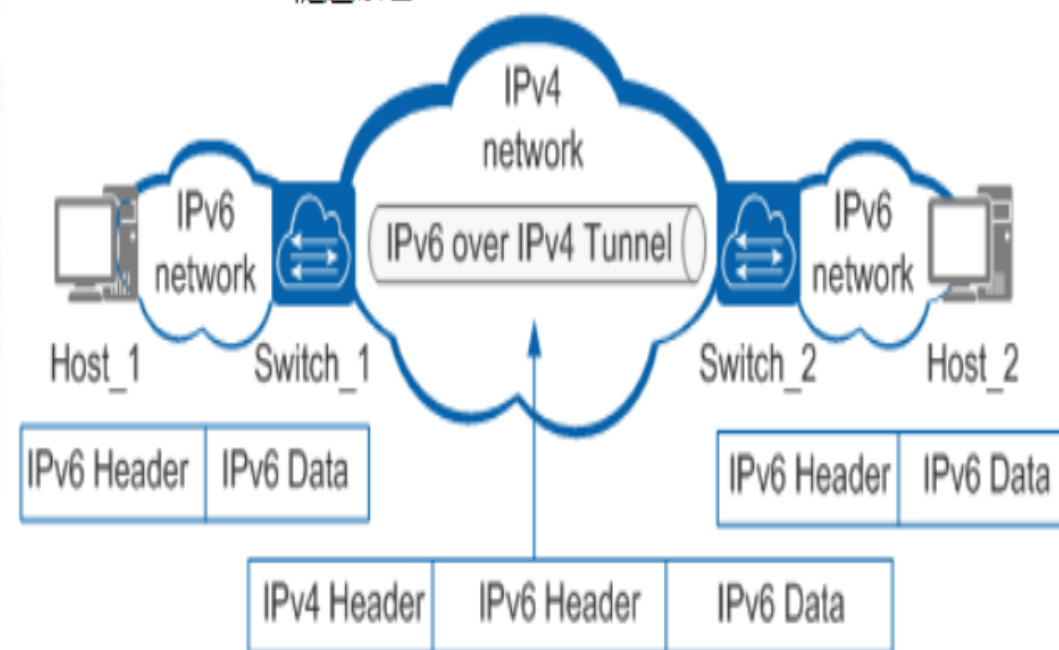
- ◆ IPv6 IDS/IPS/FW等升级
- ◆ IPv6 访问控制及隔离
- ◆ IPv6 定向安全扫描及检测

◆ IPv6过渡技术安全

- ◆ 隧道技术：6PE、6VPE、手工隧道、GRE、L2TP、6over4、4over6、6to4、ISATAP、Teredo 等，认证、加密、完整性、访问控制等措施。
- ◆ 翻译技术：NAT-PT、NAT64、IVI等，防地址池耗尽攻击等
- ◆ IPv6/IPv4双栈技术：IPv6默认是激活的，但需要和IPv4一样加强部署IPv6的安全策略。

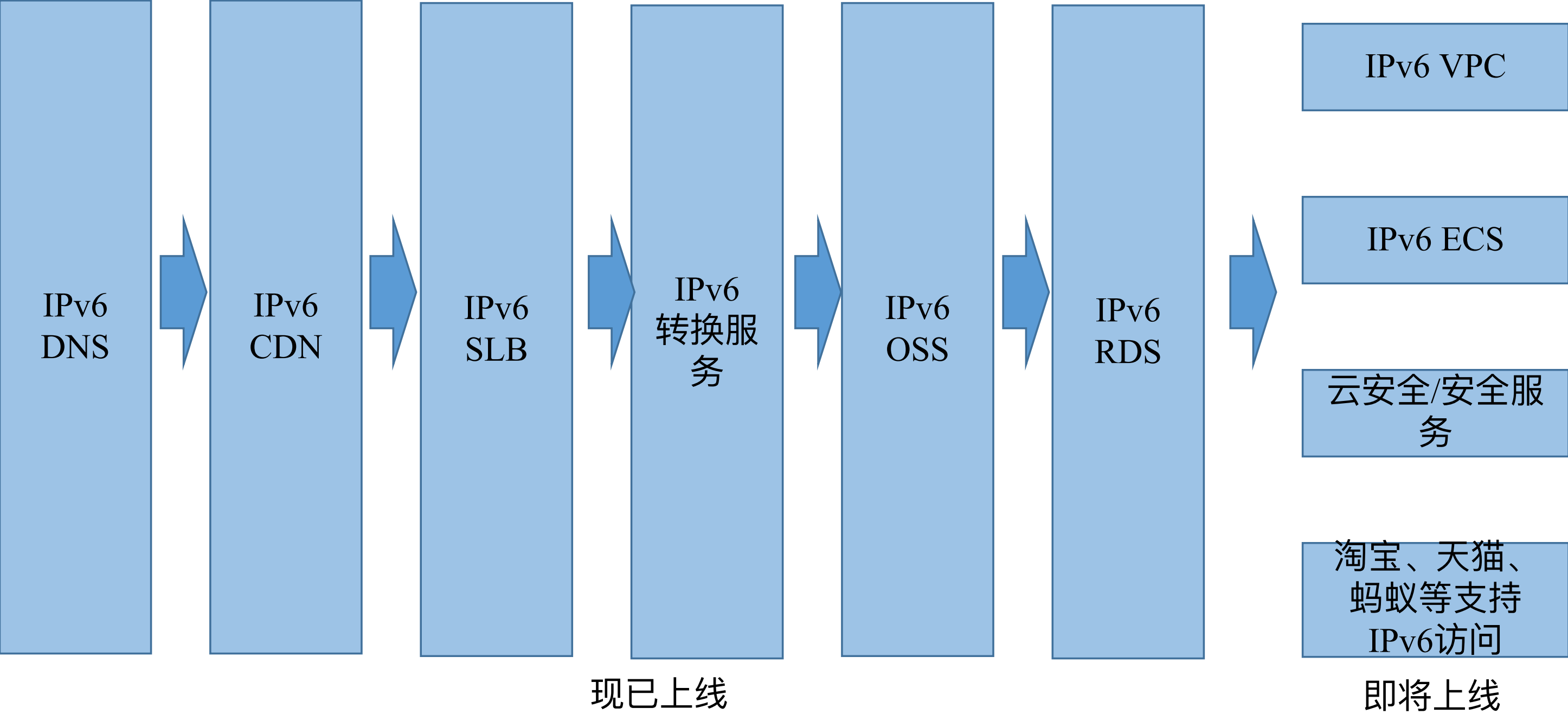


IPv6 over IPv4隧道原理



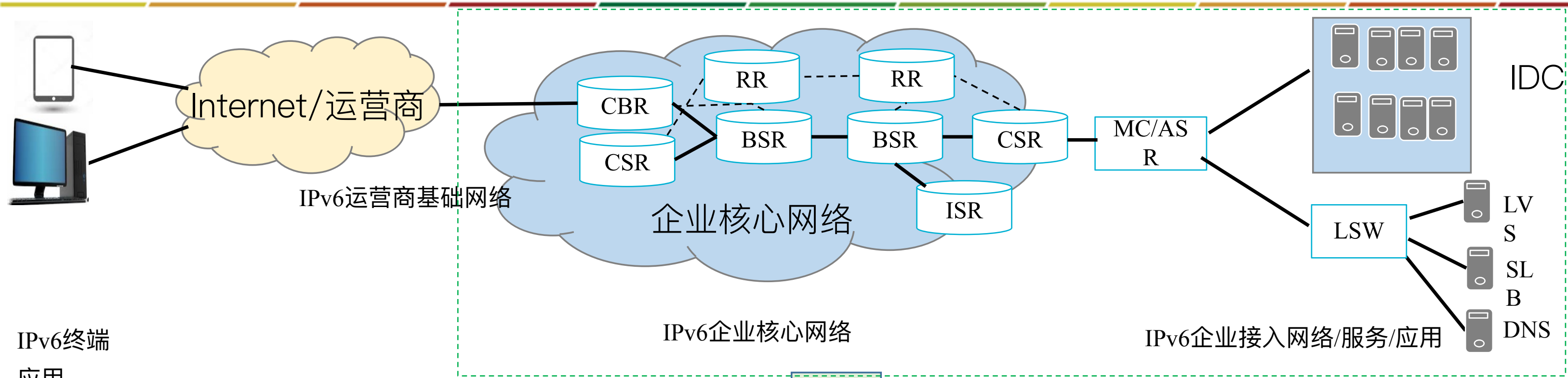
阿里巴巴集团IPv6改造及安全解决方案

阿里巴巴IPv6产品及应用改造

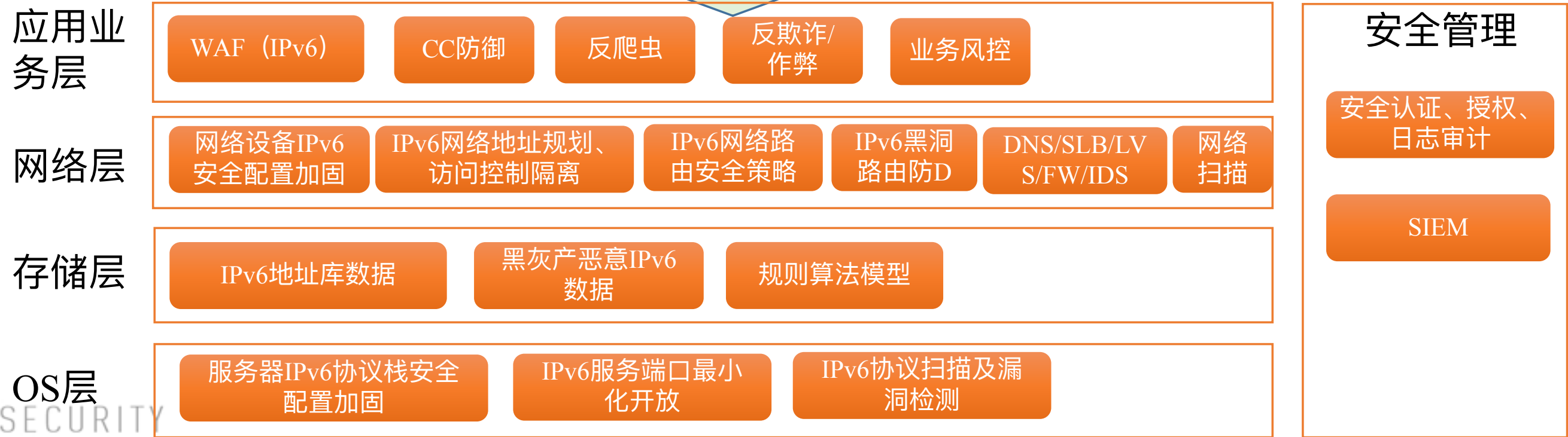


自2012年全球IPv6网络正式启动以来，阿里巴巴就已开始着手IPv6的网络研发的设备选型及升级路线改造，6年厚积薄发，阿里云已是目前国内唯一一家全面提供IPv6服务的云厂商。

阿里巴巴集团IPv6安全解决方案-多层纵深防御



IPv6安全改造方案



未来IPv6安全的思考及展望

- 1、建立自主可控完备高效的IPv6安全防护网络需要从标准、应用、端、管、云及各行各业的共同努力，特别是IPv6编址、精确溯源等方面需要政府主导规范、行业间共建共享。
- 2、IPv6协议栈稳定会有有一个过程，随着支持IPv6应用逐步上线，用户流量上一定规模，会有新一轮新形式的IPv6攻防对抗，特别是在业务风控、防D、IPv6协议漏洞挖掘等方面。
- 3、IPv6随着政策牵引以及5G、IoT、云计算等对于IP地址需求大的业务不断成熟，会迎来一个快速发展期， IPv6安全产品及检测防护升级需要及时READY，确保安全风险可控。

Q&A



ISC 互联网安全大会



360 互联网安全中心

谢谢!

2018 ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
(原中国互联网安全大会)